Yavuzlar Restoran Sitesi Pentest

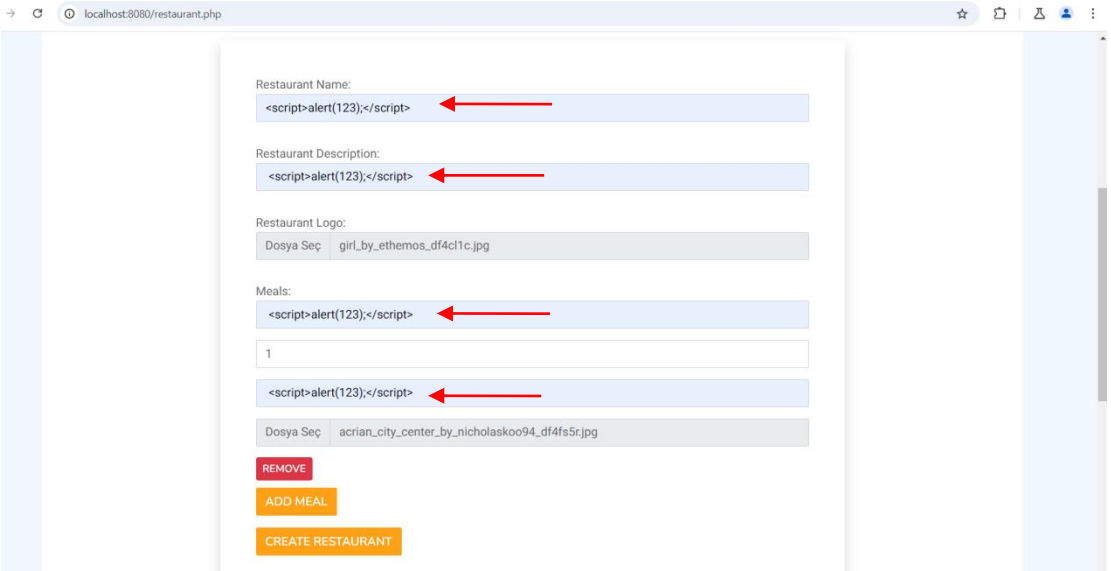
Feyzanur Yüksel

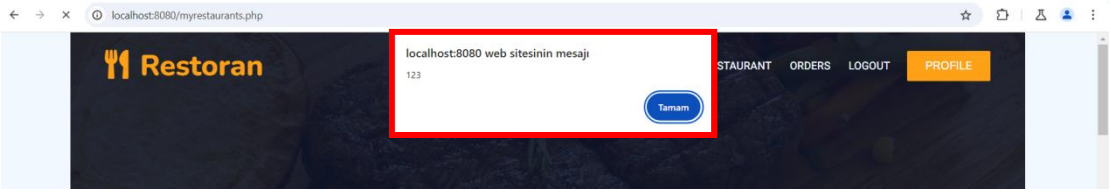
XSS

XSS (Cross-Site Scripting) siteye zararlı JavaScript kodlarını enjekte ederek diğer kullanıcıların tarayıcılarında çalıştırmasına olanak tanıyan bir güvenlik açığıdır. Bu tür saldırılar ile saldırgan, kullanıcı bilgilerini çalabilir, cookieleri ele geçirebilir, sahte içerik gösterebilir.

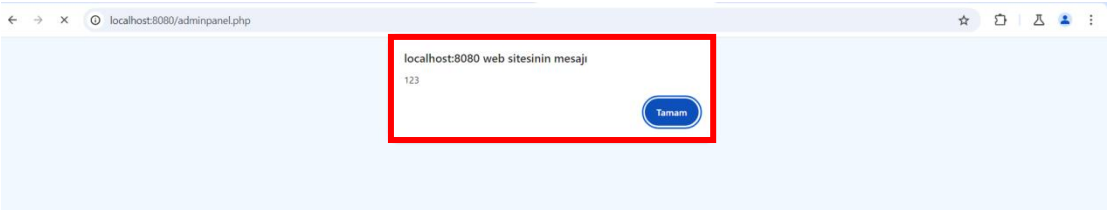
8.1
(High)

Siteye company hesabı ile kayıt olup yeni restoran eklerken, yeni yemek eklerken script payloadları denediğimde başarılı oldum.



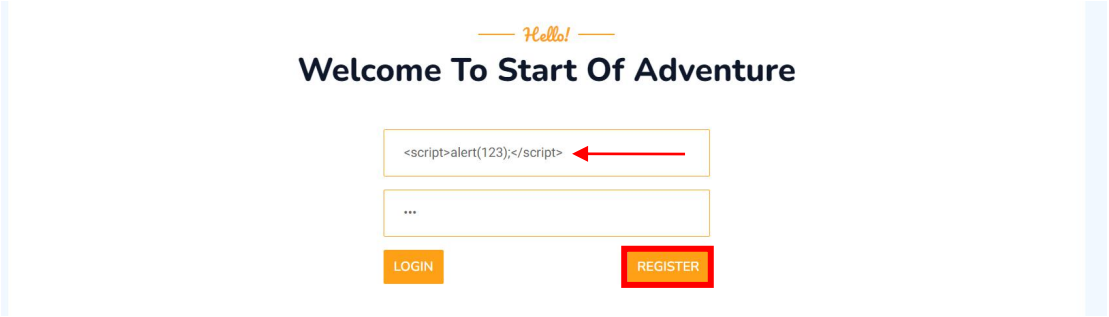


Admin hesabında bu işlemi yapmasam bile kullanıcı olarak eklediğim script çalışmakta.

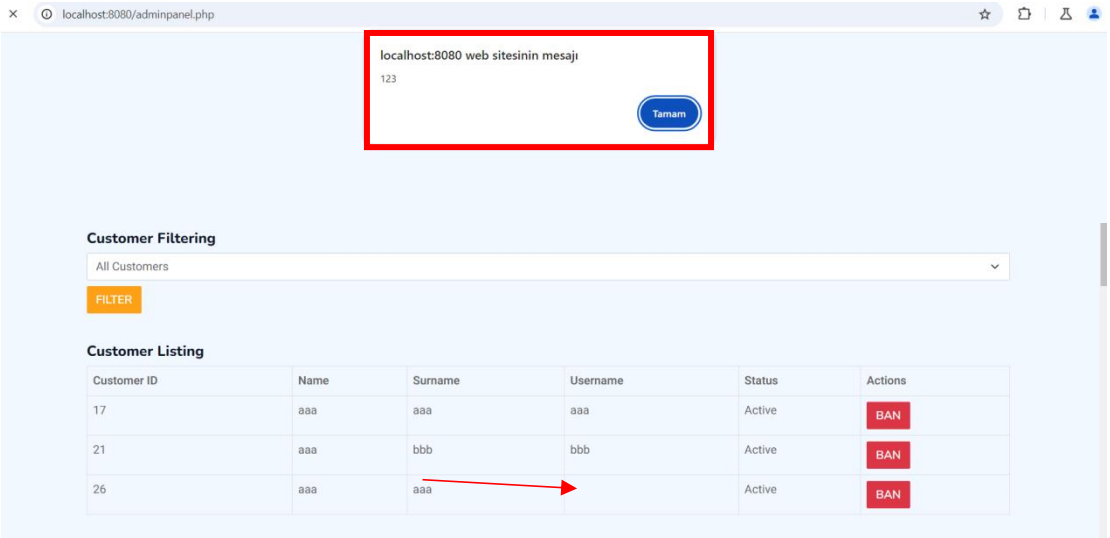


9.4
(Critical)

Kullanıcı isminde bir filtreleme olmadığı için aynı payload ile siteye kayıt olabildim.



Admin panelinden bu scriptin çalıştığını görebiliyorum.



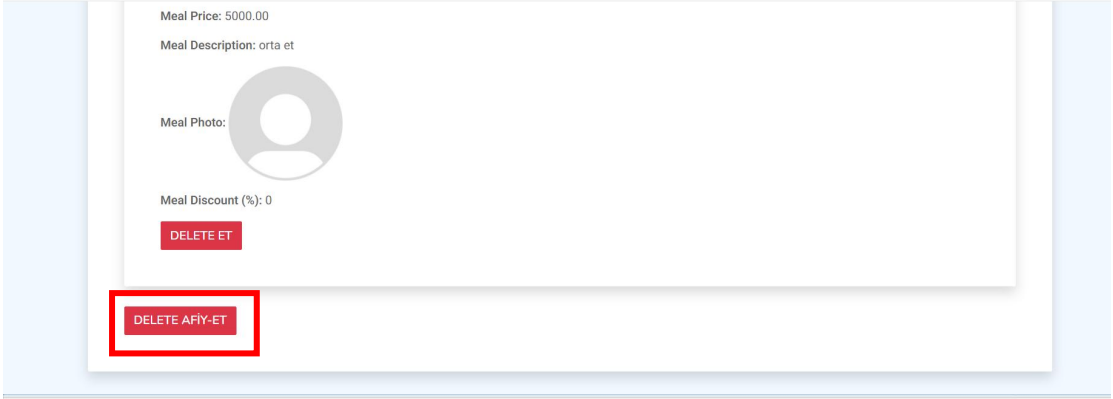
Bu zafiyeti parametreli sorgular ile, uygulamanın girdi noktalarında uygun güvenlik önlemleri alarak önleyebiliriz.

IDOR

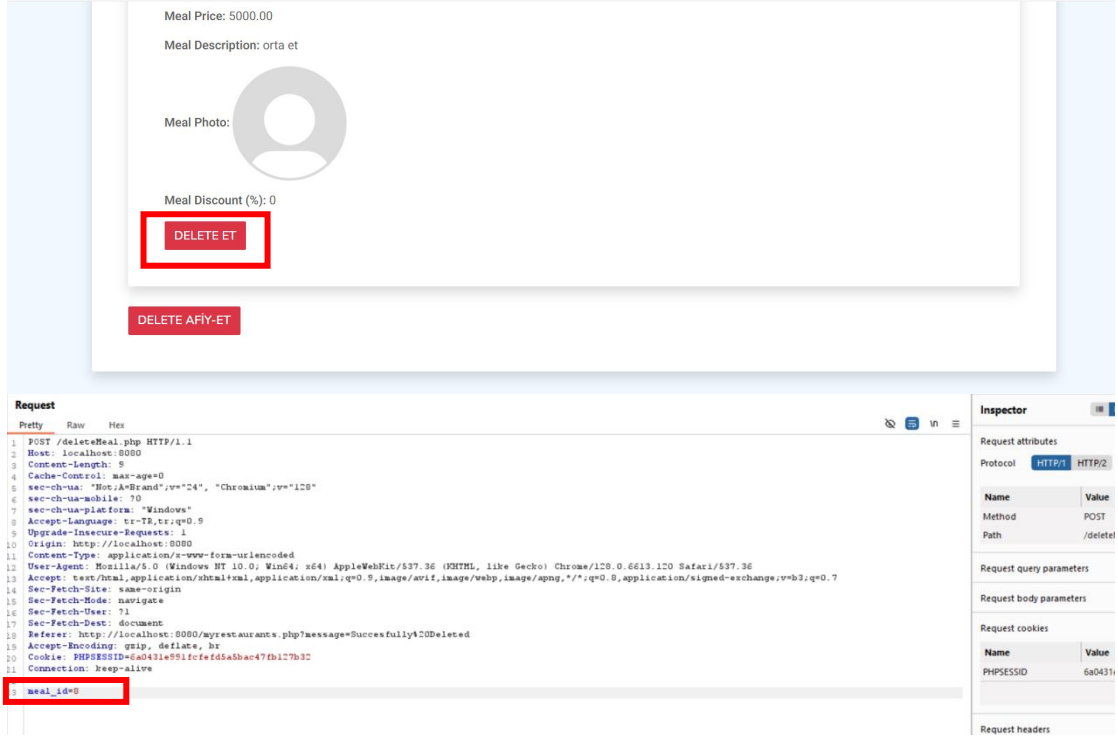
Idor zaafiyeti (Insecure Direct Object References) yetkisiz kullanıcıların isteklerdeki bilgileri görmesine, parametreleri değiştirerek verilerle oynayabilmesine, işlemlere erişebilmesine neden olur.

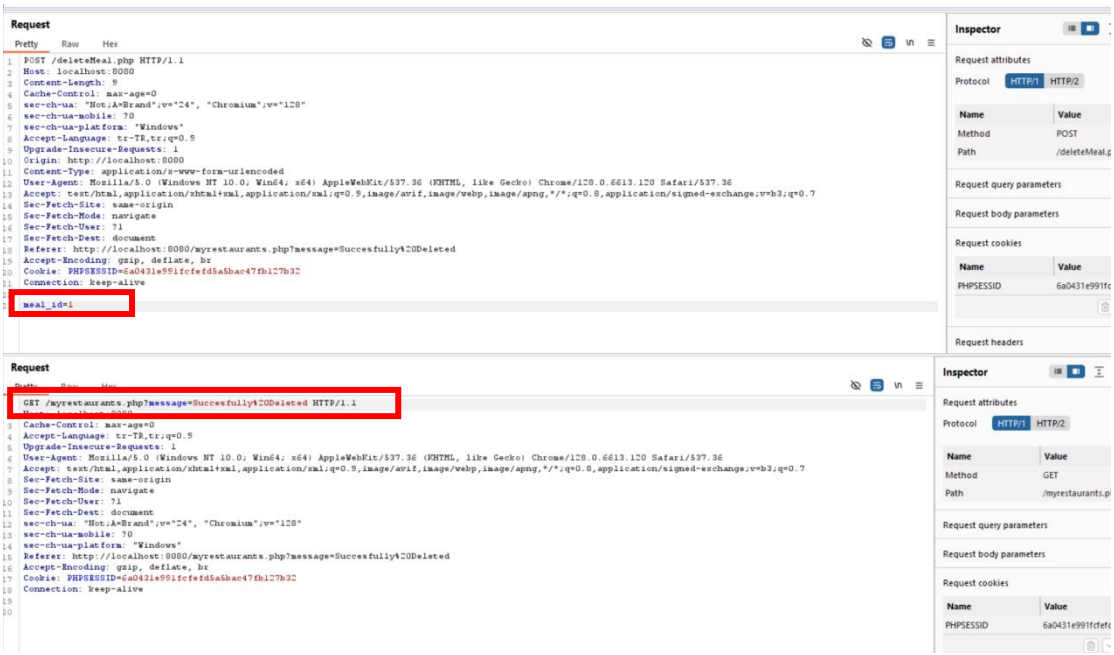
6.5 (Medium)

Company hesabıyla giriş yapıp kendi restoranımı silme isteğine göz attığımda istekte restoran id değiştirebildiğimi fark ettim. Böylece bana ait olmayan bir restoranı silebiliyorum.



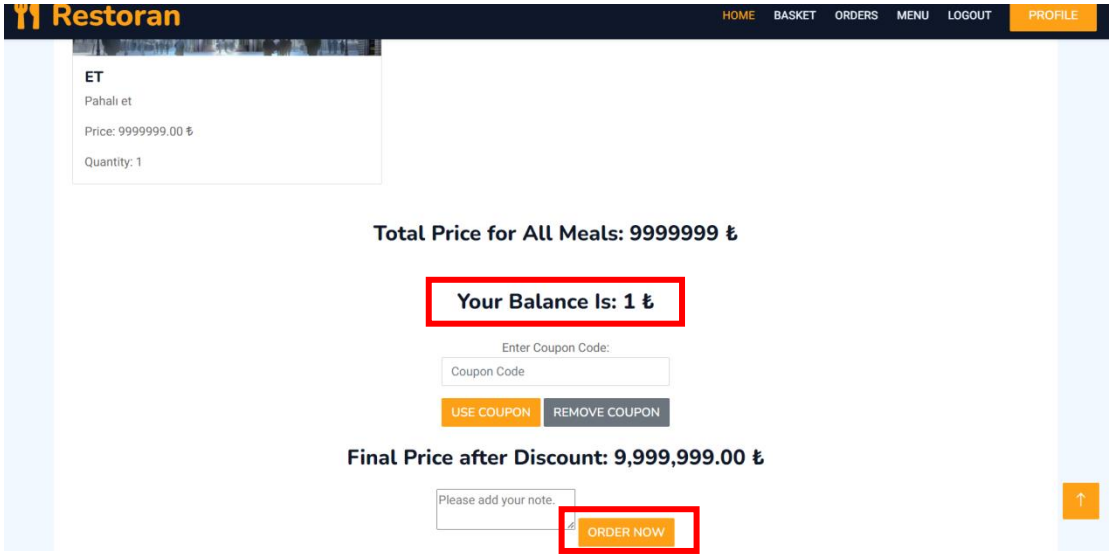
Bu işlemin aynısını bana ait olmayan restoranlarının yemek listeleri için de yapabiliyorum.

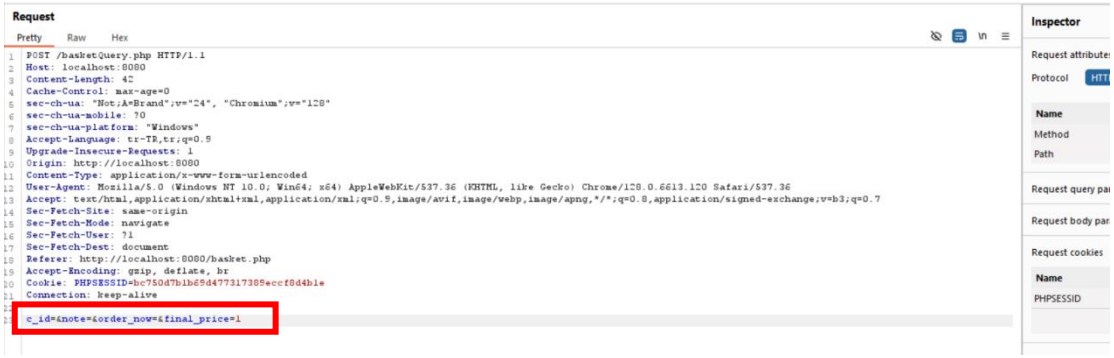




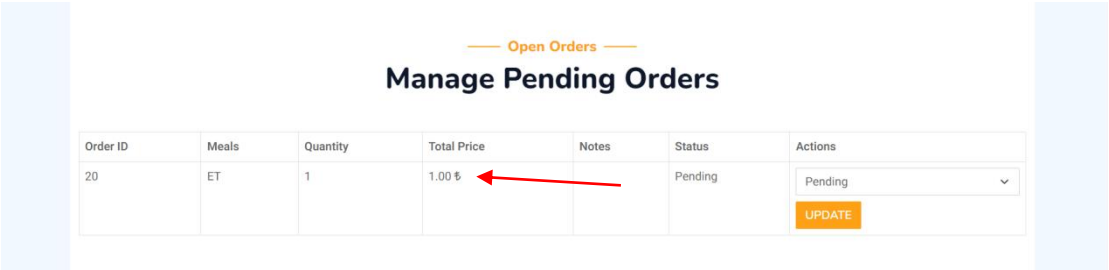
6.5
(Medium)

Kullanıcı olarak yeterli bütçem olmamasına rağmen istediğim siparişi verebiliyorum. Bu siparişi onaylayıp Burp Suite üzerinden isteği yakaladığımda final price ile oynayabildiğimi fark ettim.

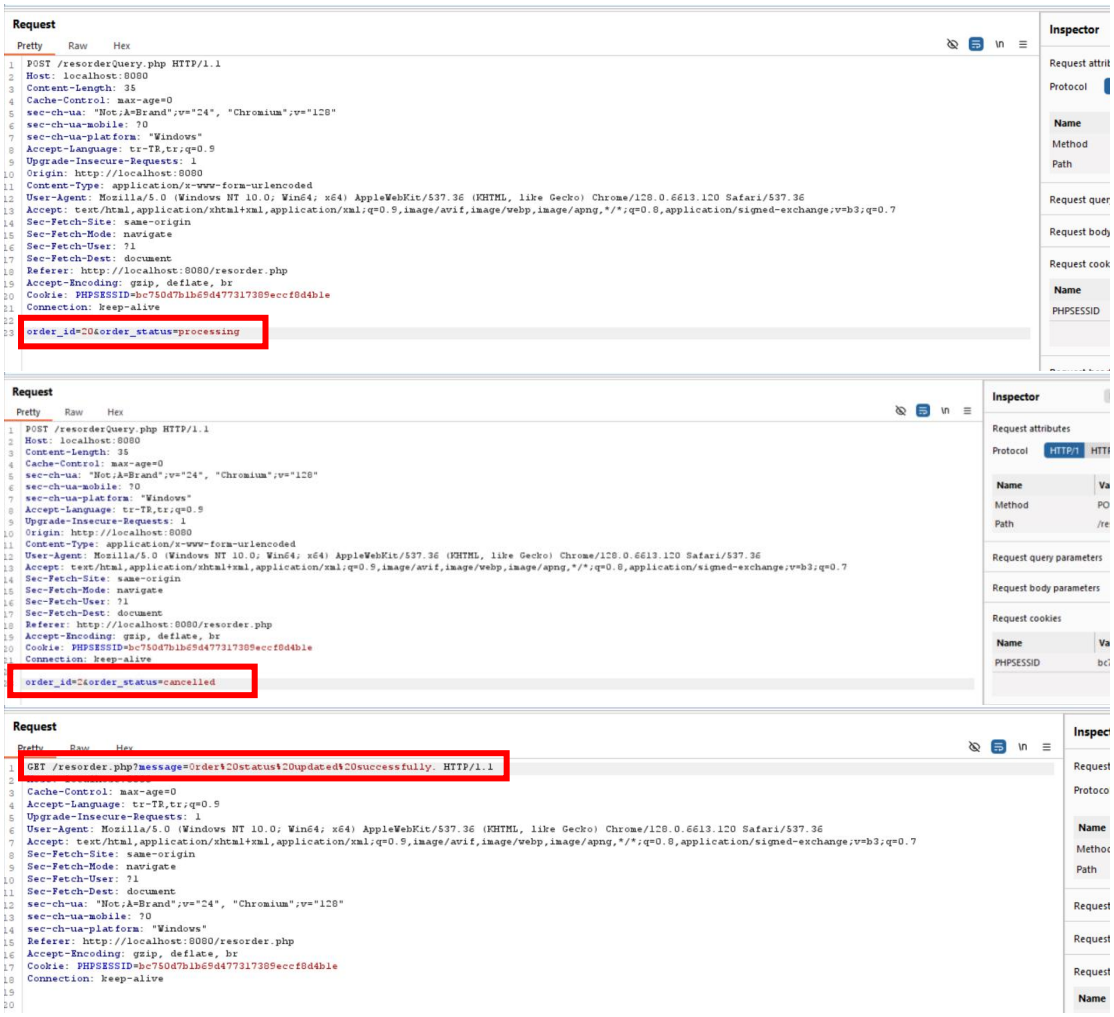




Restoran hesabından baktığımda siparişi 1 tl ile aldığımı görebiliyorum.

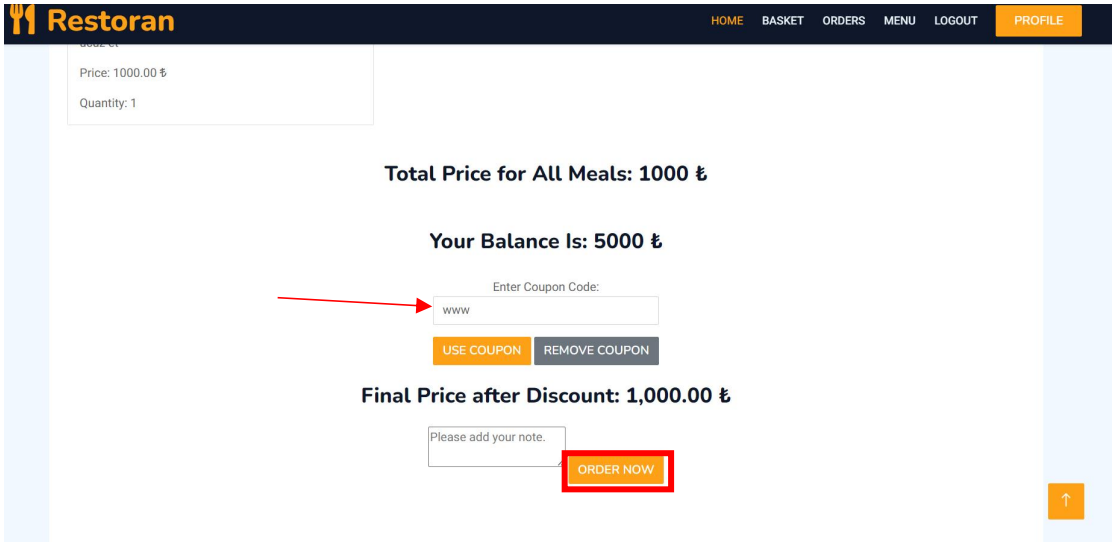


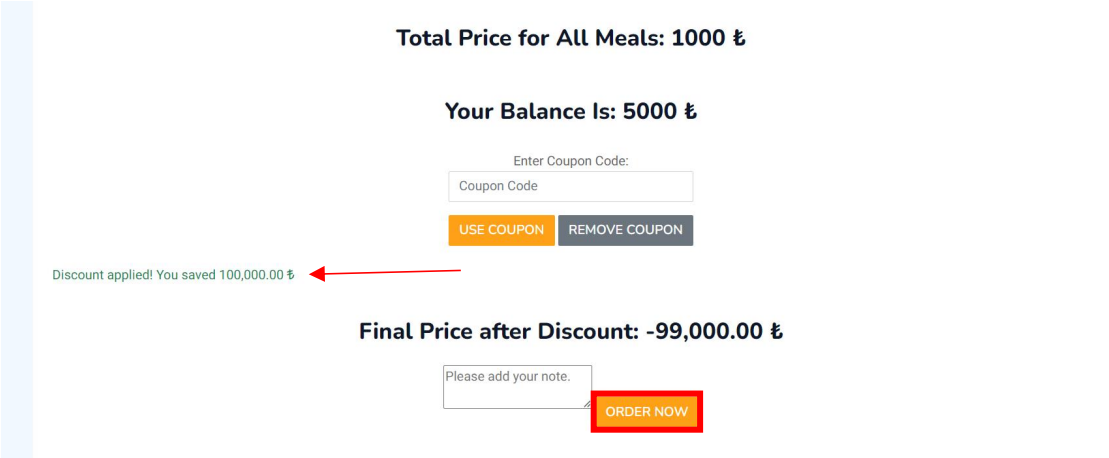
Ayrıca bu siparişin durumunu güncelleme isteğine göz attığımda benim restoranıma ait olmayan siparişlerin durumunu da kontrol edebildiğimi fark ettim. Order id ve order status kısmını değiştirdiğimde amacıma ulaştım.



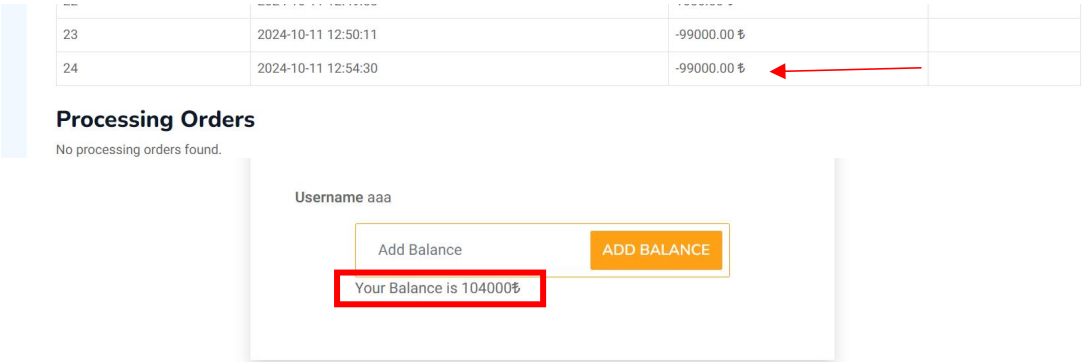
6.5
(Medium)

Sepetimdeki ürünleri almadan öncesinde admin hesabından ‘www’ kupon kodu ile 100.000 tl indirim tanımladım.

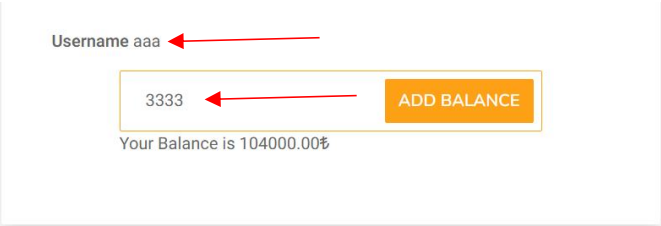




Siparişimi onayladığımda siparişi kabul ederek kupondan artan miktarı bütçeme ekledi.



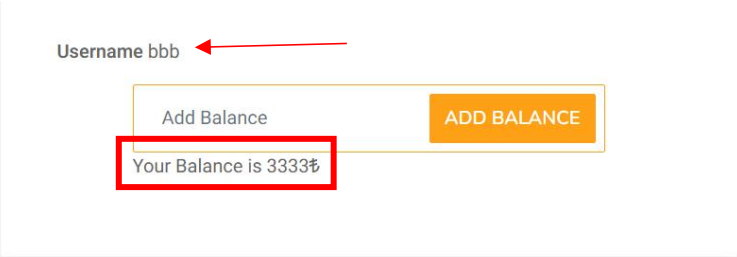
Kendi profilimden add balance isteğini incelediğimde başka kullanıcının id numarasını girerek onun bütçesini artırıp azaltabiliyorum.


Username aaa
3333
ADD BALANCE
Your Balance is 104000.00₺

Request
Pretty
Raw
Hex
Content-Length: 246
Cache-Control: max-age=0
sec-ch-ua: "Not;A=Brand";v="24", "Chromium";v="128"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Accept-Language: tr-TR,tr;q=0.9
Upgrade-Insecure-Requests: 1
Origin: http://localhost:8080
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryjmI5YKdEC4BI9ydZ
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.6613.120 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://localhost:8080/profile.php
Accept-Encoding: gzip, deflate, br
Cookie: PHPSESSID=bc750d7b1b69d477317389eccf8d4b1e
Connection: keep-alive
Content-Disposition: form-data; name="balance"
3333
------WebKitFormBoundaryjmI5YKdEC4BI9ydZ
Content-Disposition: form-data; name="balance_user_id"
17
Search
0 highlights

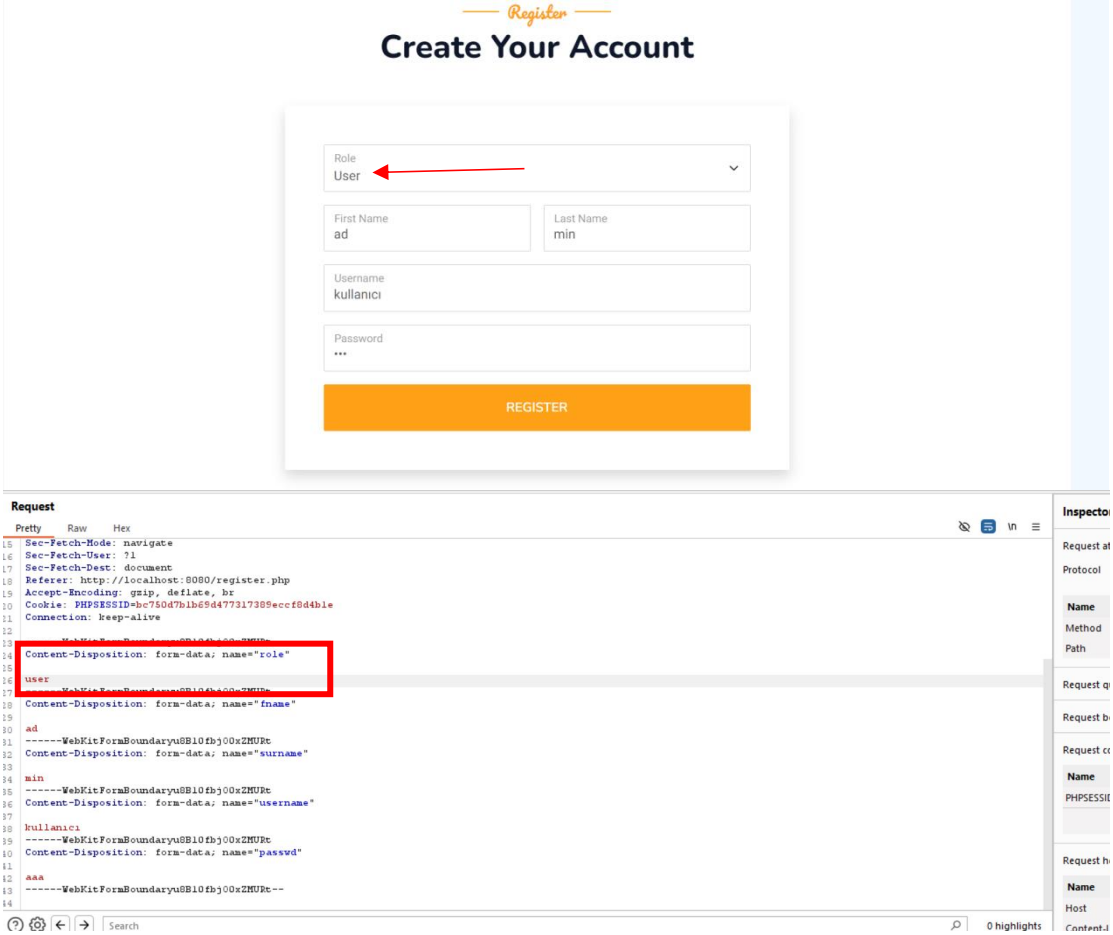
Request
Pretty
Raw
Hex
Content-Length: 246
Cache-Control: max-age=0
sec-ch-ua: "Not;A=Brand";v="24", "Chromium";v="128"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Accept-Language: tr-TR,tr;q=0.9
Upgrade-Insecure-Requests: 1
Origin: http://localhost:8080
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryjmI5YKdEC4BI9ydZ
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.6613.120 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://localhost:8080/profile.php
Accept-Encoding: gzip, deflate, br
Cookie: PHPSESSID=bc750d7b1b69d477317389eccf8d4b1e
Connection: keep-alive
Content-Disposition: form-data; name="balance"
3333
------WebKitFormBoundaryjmI5YKdEC4BI9ydZ
Content-Disposition: form-data; name="balance_user_id"
21
Search
0 highlights

Request
Pretty
Raw
Hex
GET /profile.php?message=BalanceUpdated HTTP/1.1
Cache-Control: max-age=0
Accept-Language: tr-TR,tr;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.6613.120 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
sec-ch-ua: "Not;A=Brand";v="24", "Chromium";v="128"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Referer: http://localhost:8080/profile.php
Accept-Encoding: gzip, deflate, br
Cookie: PHPSESSID=bc750d7b1b69d477317389eccf8d4b1e
Connection: keep-alive

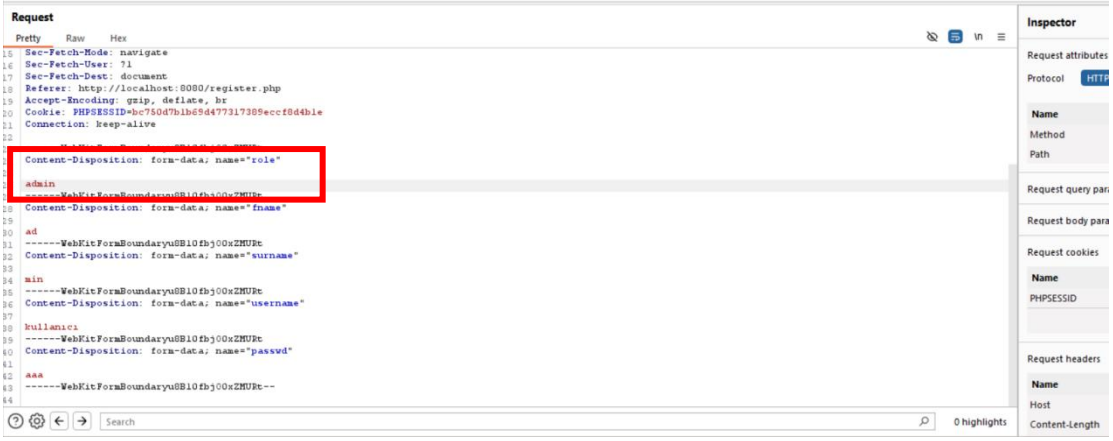

Username bbb
Add Balance
ADD BALANCE
Your Balance is 3333₺

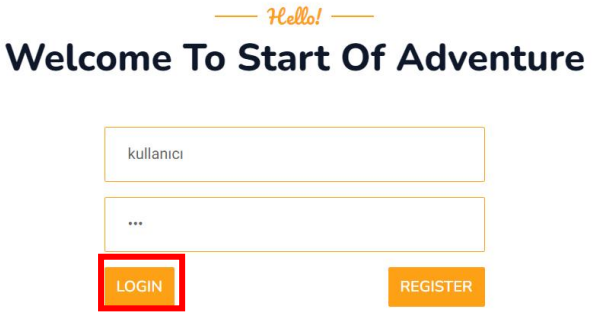
9.1
(Critical)

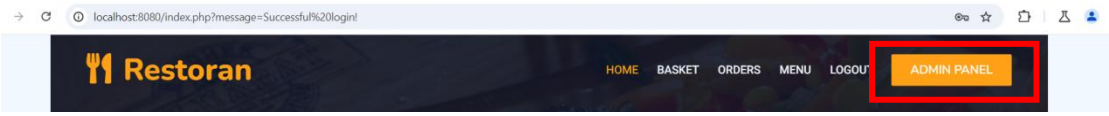
Kullanıcı rolü ile kayıt olduğum isteği Burp Suite ile yakaladığımda rolümü değiştirebildiğimi fark ettim.



Rolümü admin olarak değiştirdiğimde başarılı bir şekilde siteye kayıt olabildim.







Erişim kontrollerini güçlendirerek, her kullanıcıya sadece yetkili olduğu verilere erişim izni vererek, hassas bilgileri URL veya form verilerinde doğrudan kullanmak yerine rastgele oluşturulmuş referanslar kullanarak bu zafiyeti önleyebiliriz.